

CONFIDENTIAL · OFFENSIVE SECURITY ENGAGEMENT

# Penetration Test Report

*External Network Infrastructure & Web Application  
Security Assessment*

**REDACTED SAMPLE REPORT**

This document is a sanitised, illustrative sample provided so prospective clients can evaluate SynapseCyber's reporting format, methodology, and depth. The client, hosts, addresses, findings, and all data within are fictitious and redacted. It does not describe any real organisation or assessment.

|                |                                                        |
|----------------|--------------------------------------------------------|
| CLIENT         | ██████████ (redacted)                                  |
| ENGAGEMENT     | External Penetration Test & Web Application Assessment |
| REFERENCE      | SC-2026-PT-0142                                        |
| CLASSIFICATION | CONFIDENTIAL, Restricted Distribution                  |
| REPORT VERSION | 1.0 (Final)                                            |
| TESTING WINDOW | 14 to 25 April 2026                                    |
| REPORT DATE    | 2 May 2026                                             |
| PREPARED BY    | SynapseCyber Offensive Security Team                   |

# Confidentiality & Legal Notice

---

This report is the confidential property of the Client and SynapseCyber and is intended solely for the named recipients. It contains sensitive information regarding the security posture of the Client's systems. Distribution, reproduction, or disclosure, in whole or in part, to any party outside the authorised distribution list is prohibited without the prior written consent of the Client.

## Point-in-Time Assessment

The findings represent the security posture of the in-scope environment as observed during the defined testing window only. Environments change continuously; new vulnerabilities emerge and configurations are modified. This report should not be interpreted as a guarantee that the in-scope systems are free of vulnerabilities, nor that all vulnerabilities present were identified. A penetration test is a point-in-time, best-effort exercise constrained by time, scope, and the rules of engagement.

## No Warranty

This assessment was conducted using professional methodologies and reasonable care. SynapseCyber makes no warranty, express or implied, that the in-scope systems are secure against every possible attack. Remediation of identified findings does not eliminate all risk. The Client retains ownership of, and accountability for, decisions made on the basis of this report.

## Illustrative Sample Notice

This particular document is a redacted sample. All organisation names, hostnames, network addresses, identifiers, vulnerabilities, evidence, and data contained herein are fictitious and provided for demonstration purposes only. Any resemblance to a real organisation, system, or assessment is coincidental.

# Document Control

## Version History

| Version | Date        | Author                        | Description                            |
|---------|-------------|-------------------------------|----------------------------------------|
| 0.1     | 26 Apr 2026 | Lead Consultant (redacted)    | Internal draft, findings consolidated  |
| 0.9     | 29 Apr 2026 | Technical Reviewer (redacted) | Quality assurance and peer review      |
| 1.0     | 2 May 2026  | Engagement Manager (redacted) | Final, approved and released to Client |

## Prepared / Reviewed / Approved

| Role                    | Name                  | Function                     |
|-------------------------|-----------------------|------------------------------|
| Lead Penetration Tester | ██████████ (redacted) | Testing & primary authorship |
| Technical Reviewer      | ██████████ (redacted) | Independent QA review        |
| Engagement Manager      | ██████████ (redacted) | Approval & client delivery   |

## Distribution List

| Recipient             | Organisation / Role                        |
|-----------------------|--------------------------------------------|
| ██████████ (redacted) | Client, Chief Information Security Officer |
| ██████████ (redacted) | Client, Head of IT Operations              |
| ██████████ (redacted) | SynapseCyber, Engagement Manager           |

## Contact

### SynapseCyber Offensive Security

Engagement enquiries and remediation support: [security@synapsecyber.io](mailto:security@synapsecyber.io) · Responsible disclosure: see [synapsecyber.io/security.txt](https://synapsecyber.io/security.txt)

# Contents

---

|                                                                                      |           |
|--------------------------------------------------------------------------------------|-----------|
| <b>1. Executive Summary.....</b>                                                     | <b>6</b>  |
| 1.1 Engagement Overview.....                                                         | 6         |
| 1.2 Scope at a Glance.....                                                           | 6         |
| 1.3 Summary of Findings.....                                                         | 6         |
| 1.4 Overall Security Posture.....                                                    | 6         |
| 1.5 Key Risk Themes.....                                                             | 7         |
| 1.6 Strategic Recommendations.....                                                   | 7         |
| <b>2. Engagement Overview &amp; Methodology.....</b>                                 | <b>8</b>  |
| 2.1 Objectives.....                                                                  | 8         |
| 2.2 Scope.....                                                                       | 8         |
| 2.3 Rules of Engagement.....                                                         | 8         |
| 2.4 Assessment Timeline.....                                                         | 9         |
| 2.5 Testing Approach.....                                                            | 9         |
| 2.6 Methodology & Standards.....                                                     | 9         |
| 2.7 Phased Methodology.....                                                          | 9         |
| 2.8 Risk Rating Methodology: S.I.R.P. v2.1.....                                      | 10        |
| 2.9 Tooling.....                                                                     | 10        |
| <b>3. Summary of Findings.....</b>                                                   | <b>11</b> |
| <b>4. Detailed Findings.....</b>                                                     | <b>12</b> |
| 4.1 SC-001: SQL Injection in Customer Authentication Endpoint.....                   | 12        |
| 4.2 SC-002: Multi-Factor Authentication Not Enforced on External Remote Access.....  | 14        |
| 4.3 SC-003: Broken Object-Level Authorization (IDOR) Exposing Customer Records.....  | 16        |
| 4.4 SC-004: End-of-Life Edge Appliance with Known Exploitable Vulnerabilities.....   | 18        |
| 4.5 SC-005: Source Code & Configuration Exposure via Accessible .git Directory.....  | 20        |
| 4.6 SC-006: Weak Transport Layer Security (TLS) Configuration.....                   | 22        |
| 4.7 SC-007: Missing HTTP Security Headers.....                                       | 24        |
| 4.8 SC-008: Verbose Error Messages Disclosing Stack Traces and Internal Details..... | 26        |
| 4.9 SC-009: Session Cookies Missing Secure and HttpOnly Attributes.....              | 28        |
| 4.10 SC-010: Web Server, Framework, and Technology Version Disclosure.....           | 30        |
| 4.11 SC-011: Clickjacking via Missing Anti-Framing Controls.....                     | 31        |
| 4.12 SC-012: Email Authentication (SPF / DKIM / DMARC) Hardening Opportunities.....  | 32        |
| <b>5. Strategic Recommendations &amp; Remediation Roadmap.....</b>                   | <b>34</b> |
| 5.1 Root-Cause Themes & Programme Recommendations.....                               | 34        |
| 5.2 Prioritised Remediation Roadmap.....                                             | 34        |
| 5.3 Re-Testing.....                                                                  | 35        |
| <b>6. Conclusion.....</b>                                                            | <b>36</b> |
| <b>Appendices.....</b>                                                               | <b>37</b> |
| Appendix A: S.I.R.P. v2.1 Risk Rating Methodology.....                               | 37        |
| Appendix B: CVSS v4.0 Severity Scale.....                                            | 39        |

Appendix C: Tools & Techniques..... 39

Appendix D: MITRE ATT&CK Technique Mapping..... 39

Appendix E: Scope Limitations & Assumptions..... 39

Appendix F: Re-Testing & Validation Policy..... 40

Appendix G: Glossary..... 41

Appendix H: Standards & References..... 41

# 1. Executive Summary

## 1.1 Engagement Overview

SynapseCyber was engaged by the Client to conduct an external penetration test and web application security assessment of the Client's internet-facing infrastructure and customer-facing web portal. The objective was to evaluate the resilience of these assets against a motivated external attacker, to identify exploitable security weaknesses before an adversary could, and to provide clear, prioritised, business-aligned remediation guidance.

Testing was performed from an external (internet) perspective using a grey-box approach, between 14 to 25 April 2026. The assessment followed industry-recognised methodologies: the Penetration Testing Execution Standard (PTES), the OWASP Web Security Testing Guide, and NIST SP 800-115, with adversary techniques mapped to MITRE ATT&CK and control context aligned to Canadian Centre for Cyber Security (CCCS) guidance.

## 1.2 Scope at a Glance

| Engagement Type                           | Perspective                               | Approach |
|-------------------------------------------|-------------------------------------------|----------|
| External infrastructure + web application | Unauthenticated & authenticated, external | Grey-box |

Full scope detail, in-scope assets, and exclusions are set out in Section 2.2.

## 1.3 Summary of Findings

SynapseCyber identified 12 findings across the in-scope environment. The distribution by severity, rated using SynapseCyber's S.I.R.P. v2.1 methodology (Appendix A), is shown below.

| Severity      | Count | Distribution |
|---------------|-------|--------------|
| Critical      | 1     | <div></div>  |
| High          | 3     | <div></div>  |
| Medium        | 4     | <div></div>  |
| Low           | 3     | <div></div>  |
| Informational | 1     | <div></div>  |
| Total         | 12    |              |

## 1.4 Overall Security Posture

|                                                               |                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
|---------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <div><div>ELEVATED</div><div>Residual risk rating</div></div> | The in-scope environment presents an ELEVATED residual risk. One Critical and three High-severity findings provide realistic paths to compromise of customer personal and financial data from an unauthenticated external position. The Critical SQL injection (SC-001), the absence of MFA on remote access (SC-002), the object-level authorisation flaw (SC-003), and the exposed end-of-life edge appliance (SC-004) are individually serious and, in |
|---------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

combination, materially increase the likelihood of a reportable breach. With focused remediation of the Critical and High findings, the residual risk can be reduced to Moderate within the recommended timelines.

## 1.5 Key Risk Themes

Four root-cause themes underlie the findings. Addressing these systemically (rather than only the individual symptoms) will yield the greatest durable improvement:

- Insecure input handling. Injection and verbose error conditions (SC-001, SC-008) indicate that untrusted input is not consistently validated, parameterised, or safely handled across the application.
- Authentication and access-control gaps. Single-factor remote access and broken object-level authorisation (SC-002, SC-003) expose the environment to credential-based attacks and unauthorised data access.
- Asset and patch lifecycle. An exposed end-of-life appliance and deprecated transport configuration (SC-004, SC-006) point to gaps in lifecycle and vulnerability management of internet-facing assets.
- Configuration hygiene. Exposed metadata, missing security headers, banner disclosure, weak cookie flags, clickjacking exposure, and email-authentication gaps (SC-005, SC-007, SC-009 to SC-012) reflect the absence of an enforced secure-baseline standard for public-facing services.

## 1.6 Strategic Recommendations

The following leadership-level actions are recommended; detailed, finding-level guidance appears in Section 4 and the prioritised roadmap in Section 5.

1. Remediate the Critical and High findings on an emergency footing (SC-001 and SC-004 within 72 hours; SC-002 and SC-003 within 7 days).
2. Enforce phishing-resistant MFA across all external authentication surfaces.
3. Establish a secure software development lifecycle with automated SAST, DAST, and dependency (SCA) gates in the CI/CD pipeline.
4. Implement an attack-surface and vulnerability-management programme with risk-based remediation SLAs and recurring validation testing.
5. Adopt and enforce a secure-configuration baseline for all internet-facing services, aligned to CCCS guidance and OSFI Guideline B-13.

## 2. Engagement Overview & Methodology

### 2.1 Objectives

- Identify and validate exploitable vulnerabilities in the in-scope internet-facing infrastructure and web application.
- Assess the potential business impact of identified weaknesses, including exposure of customer personal and financial data.
- Evaluate the effectiveness of perimeter, authentication, and application-layer controls against a realistic external attacker.
- Provide clear, prioritised, and actionable remediation guidance aligned to the Client's risk profile and regulatory obligations.

### 2.2 Scope

#### In Scope

| Asset / Target                 | Description                                   |
|--------------------------------|-----------------------------------------------|
| portal.██████████.com          | Customer-facing web portal and supporting API |
| www.██████████.com             | Corporate marketing website                   |
| vpn.██████████.com             | Remote-access VPN gateway                     |
| ████.████.████.0/24 (redacted) | External network range, perimeter hosts       |

#### Out of Scope

- Denial-of-service and volumetric / stress testing.
- Social-engineering and physical-security testing (not authorised for this engagement).
- Third-party / cloud-provider underlying infrastructure beyond the Client's configuration responsibility.
- Any host, domain, or address not explicitly listed in the in-scope table.

### 2.3 Rules of Engagement

Testing was governed by a signed authorisation and rules-of-engagement agreement. Key constraints:

- All activity was confined to the agreed scope and testing window, from authorised source addresses.
- No destructive, denial-of-service, or data-altering actions were permitted; exploitation was conducted only to the minimum extent required to validate a finding.
- Only Client-provisioned test accounts and test data were used; no production customer records were accessed or exfiltrated.
- An emergency escalation contact and stop-test procedure were agreed in advance and remained available throughout.

## 2.4 Assessment Timeline

| Phase                            | Dates                | Activity                                         |
|----------------------------------|----------------------|--------------------------------------------------|
| Planning & scoping               | 9 to 11 Apr 2026     | Scope confirmation, ROE, authorisation           |
| Reconnaissance & enumeration     | 14 to 16 Apr 2026    | Passive/active discovery, attack-surface mapping |
| Vulnerability analysis           | 16 to 19 Apr 2026    | Scanning, manual analysis, validation            |
| Exploitation & post-exploitation | 19 to 25 Apr 2026    | Controlled exploitation, impact validation       |
| Reporting & QA                   | 26 Apr to 2 May 2026 | Analysis, peer review, delivery                  |

## 2.5 Testing Approach

A grey-box approach was adopted: SynapseCyber was provided with the in-scope target list and low-privilege test credentials but no source code or privileged internal documentation. This balances realism with efficient coverage: it reflects the position of an external attacker who has obtained, or can plausibly obtain, a standard user account, while ensuring authenticated functionality is exercised within the available time.

## 2.6 Methodology & Standards

Testing was conducted in alignment with the following recognised standards and frameworks:

| Standard / Framework                             | Application to this Engagement                                  |
|--------------------------------------------------|-----------------------------------------------------------------|
| PTES (Penetration Testing Execution Standard)    | Overall engagement structure and phased execution               |
| NIST SP 800-115                                  | Technical guide to information security testing and assessment  |
| OWASP Web Security Testing Guide (WSTG v4.2)     | Web application test cases and coverage                         |
| OWASP Top 10 (2021) & API Security Top 10 (2023) | Finding categorisation and risk framing                         |
| MITRE ATT&CK                                     | Mapping of observed adversary techniques (Appendix D)           |
| CCCS ITSG-33 / ITSAP series                      | Canadian control context and remediation references             |
| OSFI Guideline B-13                              | Sector alignment for federally regulated financial institutions |

## 2.7 Phased Methodology

1. Reconnaissance: passive and active discovery of in-scope assets, services, and attack surface (DNS, certificate transparency, service enumeration).
2. Scanning & enumeration: authenticated and unauthenticated scanning, technology fingerprinting, and content discovery.
3. Vulnerability analysis: correlation of automated results with expert manual analysis to eliminate false positives and identify logic flaws tools miss.

4. Exploitation: controlled, minimal validation of confirmed weaknesses, strictly within the rules of engagement.
5. Post-exploitation: assessment of realistic business impact and potential for lateral movement, without destructive action.
6. Reporting: risk-rated findings, evidence, and prioritised remediation, subject to independent peer review before delivery.

## 2.8 Risk Rating Methodology: S.I.R.P. v2.1

Findings are rated using SynapseCyber's proprietary S.I.R.P. v2.1 model. S.I.R.P. produces a defensible, business-aligned severity by combining four dimensions (Severity, Impact, Reproducibility, and Priority) and reconciling established standards (CVSS v4.0, the OWASP Risk Rating Methodology, EPSS, and CISA SSVC) with the criticality of the affected asset. Each finding therefore carries both a technical score and a clear, board-ready action. The full model, including the asset-tier and split-SLA matrices and the Golden Quarter protocol, is documented in Appendix A.

## 2.9 Tooling

Automated tooling was used to extend coverage and was supplemented throughout by expert manual testing, which remained the primary method. No destructive or denial-of-service tooling was used.

| Category                       | Representative Tooling                                              |
|--------------------------------|---------------------------------------------------------------------|
| Reconnaissance / OSINT         | Passive DNS, certificate transparency, public-source enumeration    |
| Network scanning               | Nmap and supporting service-enumeration tooling                     |
| Vulnerability scanning         | Authenticated and unauthenticated commercial / open-source scanners |
| Web application testing        | Intercepting proxy (Burp Suite Professional), OWASP ZAP             |
| TLS / transport analysis       | TLS configuration analysers (e.g., testssl.sh, sslyze)              |
| Manual analysis & exploitation | Bespoke scripts and controlled, authorised manual techniques        |

### 3. Summary of Findings

The table below lists all findings with their S.I.R.P. rating, equivalent CVSS v4.0 base score, and category. Detailed write-ups, evidence, and remediation guidance follow in Section 4.

| ID     | Finding                                                             | Severity      | S.I.R.P. | CVSS |
|--------|---------------------------------------------------------------------|---------------|----------|------|
| SC-001 | SQL Injection in Customer Authentication Endpoint                   | Critical      | 9.4      | 9.3  |
| SC-002 | Multi-Factor Authentication Not Enforced on External Remote Access  | High          | 8.3      | 8.1  |
| SC-003 | Broken Object-Level Authorization (IDOR) Exposing Customer Records  | High          | 8.1      | 7.7  |
| SC-004 | End-of-Life Edge Appliance with Known Exploitable Vulnerabilities   | High          | 8.6      | 8.6  |
| SC-005 | Source Code & Configuration Exposure via Accessible .git Directory  | Medium        | 6.4      | 6.5  |
| SC-006 | Weak Transport Layer Security (TLS) Configuration                   | Medium        | 5.8      | 5.9  |
| SC-007 | Missing HTTP Security Headers                                       | Medium        | 5.2      | 5.3  |
| SC-008 | Verbose Error Messages Disclosing Stack Traces and Internal Details | Medium        | 5.0      | 5.3  |
| SC-009 | Session Cookies Missing Secure and HttpOnly Attributes              | Low           | 3.4      | 3.5  |
| SC-010 | Web Server, Framework, and Technology Version Disclosure            | Low           | 2.8      | 3.1  |
| SC-011 | Clickjacking via Missing Anti-Framing Controls                      | Low           | 3.0      | 3.4  |
| SC-012 | Email Authentication (SPF / DKIM / DMARC) Hardening Opportunities   | Informational | N/A      | N/A  |

## 4. Detailed Findings

### 4.1 SC-001: SQL Injection in Customer Authentication Endpoint

**CRITICAL** · S.I.R.P. 9.4 · CVSS v4.0 9.3 · SSVc: Act

|             |                                                  |                 |                     |
|-------------|--------------------------------------------------|-----------------|---------------------|
| SEVERITY    | Critical (S.I.R.P. 9.4)                          | CVSS V4.0       | 9.3                 |
| ASSET TIER  | Tier 1 (Internet-facing)                         | REMEDIATION SLA | Immediate (≤ 72 h)  |
| EPSS        | 0.84 (97th pct)                                  | SSVC DECISION   | Act                 |
| CWE         | CWE-89                                           | CATEGORY        | A03:2021, Injection |
| CVSS VECTOR | CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H |                 |                     |

#### Affected Assets

<https://portal.████████.com/api/v1/auth/login>

#### Description

The customer portal authentication endpoint constructs backend database queries by concatenating untrusted input from the username field directly into a SQL statement, without parameterisation or input validation. SynapseCyber confirmed a time-based blind SQL injection condition: an unauthenticated attacker can influence the logic of the backend query and infer database contents through differential response timing. Database fingerprinting indicated a [DBMS redacted] backend.

#### Evidence

A conditional, time-delayed payload was submitted in the username parameter of the authentication request [payload redacted]. The endpoint exhibited a response-time differential consistent with conditional query execution, confirming injection. Controlled, read-only enumeration validated access to the customer data schema. No customer data was exfiltrated, and no write/destructive operations were performed. Supporting request/response captures are withheld from this redacted sample.

#### Business Impact

Successful exploitation permits unauthenticated read access to the customer database (including personal information, password hashes, and financial records) and may enable authentication bypass. Depending on database privileges and configuration, injection can escalate to operating-system command execution. For a Canadian federally regulated financial institution, confirmed compromise of personal information is a reportable privacy breach under PIPEDA and a material technology incident under OSFI Guideline B-13.

#### Likelihood / Exploitability

High. The endpoint is unauthenticated, internet-facing, and the condition is reliably reproducible using commodity tooling. EPSS and observed exploit practicality both indicate a high likelihood of opportunistic exploitation.

### Steps to Reproduce (sanitised)

1. Browse to the customer portal login page and initiate a sign-in request.
2. Intercept the authentication POST request with an interception proxy.
3. Replace the username value with a conditional, time-based test expression [payload redacted].
4. Compare server response latency against a control request to confirm conditional execution.
5. Full payloads, schema details, and extracted records are intentionally omitted from this redacted sample.

### Remediation

- Refactor all database access to use parameterised queries / prepared statements (or a vetted ORM). User input must never be concatenated into query strings.
- Apply strict server-side input validation and allow-listing on all parameters.
- Enforce least privilege on the application database account; remove DDL and administrative rights.
- Deploy a Web Application Firewall in blocking mode as a compensating control while code is remediated.
- Conduct a security code review of every data-access layer and integrate SAST/DAST gates into the CI/CD pipeline to prevent recurrence.

### References

- CWE-89: SQL Injection
- OWASP Top 10 A03:2021, Injection
- OWASP WSTG-INPV-05
- OWASP SQL Injection Prevention Cheat Sheet
- CCCS ITSAP.00.038

## 4.2 SC-002: Multi-Factor Authentication Not Enforced on External Remote Access

**HIGH** · S.I.R.P. 8.3 · CVSS v4.0 8.1 · SSVC: Act

|             |                                                  |                 |                                                    |
|-------------|--------------------------------------------------|-----------------|----------------------------------------------------|
| SEVERITY    | High (S.I.R.P. 8.3)                              | CVSS V4.0       | 8.1                                                |
| ASSET TIER  | Tier 1 (Internet-facing)                         | REMEDIATION SLA | 7 days                                             |
| EPSS        | 0.42 (88th pct)                                  | SSVC DECISION   | Act                                                |
| CWE         | CWE-308                                          | CATEGORY        | A07:2021, Identification & Authentication Failures |
| CVSS VECTOR | CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:L |                 |                                                    |

### Affected Assets

https://vpn.████████.com

Remote-access web portal (redacted)

### Description

The corporate VPN gateway and the external remote-access portal accept single-factor (password-only) authentication for external users. No second-factor challenge is presented. The exposed authentication surface is therefore protected solely by knowledge-based credentials.

### Evidence

Using valid, Client-provided test credentials, SynapseCyber authenticated to the external remote-access portal and established a session without being prompted for any second authentication factor. Authentication endpoints also lacked observable rate-limiting or lockout responses to repeated attempts.

### Business Impact

A single compromised credential (obtained through phishing, credential stuffing, or password spraying) grants a remote attacker an authenticated foothold into the internal environment. OSFI Guideline B-13 expects strong, phishing-resistant authentication for remote access to regulated environments, and CCCS guidance identifies MFA as a foundational control.

### Likelihood / Exploitability

High. Credential-based attacks against exposed remote-access services are among the most common initial-access techniques observed in the wild, and the absence of rate-limiting compounds the exposure.

### Steps to Reproduce (sanitised)

1. Navigate to the external remote-access portal.
2. Submit valid credentials (test account provided by the Client).
3. Observe that a session is granted with no second-factor prompt.

**Remediation**

- Enforce phishing-resistant multi-factor authentication (FIDO2 / WebAuthn preferred) on all externally reachable authentication surfaces, including VPN and remote portals.
- Implement conditional-access policies (device posture, geolocation, impossible-travel detection).
- Apply authentication rate-limiting, lockout, and anomaly alerting.
- Plan a phased migration toward passwordless authentication for privileged and remote users.

**References**

- CWE-308: Use of Single-factor Authentication
- OWASP Top 10 A07:2021
- CCCS ITSAP.00.030: Multi-factor Authentication
- OSFI Guideline B-13

### 4.3 SC-003: Broken Object-Level Authorization (IDOR) Exposing Customer Records

**HIGH** · S.I.R.P. 8.1 · CVSS v4.0 7.7 · SSVC: Act

|             |                                                  |                 |                                 |
|-------------|--------------------------------------------------|-----------------|---------------------------------|
| SEVERITY    | High (S.I.R.P. 8.1)                              | CVSS V4.0       | 7.7                             |
| ASSET TIER  | Tier 1 (Internet-facing)                         | REMEDIATION SLA | 7 days                          |
| EPSS        | 0.21 (78th pct)                                  | SSVC DECISION   | Act                             |
| CWE         | CWE-639                                          | CATEGORY        | A01:2021, Broken Access Control |
| CVSS VECTOR | CVSS:4.0/AV:N/AC:L/AT:N/PR:L/UI:N/VC:H/VI:L/VA:N |                 |                                 |

#### Affected Assets

<https://portal.████████.com/api/v1/accounts/{accountId}/statements>

#### Description

The account-statements API authorises requests on the basis of authentication alone and does not verify that the requesting principal owns the referenced object. Because account identifiers are sequential and predictable, an authenticated low-privilege user can enumerate identifiers belonging to other customers and retrieve their statements, a Broken Object-Level Authorization (BOLA / IDOR) condition.

#### Evidence

Authenticated as a low-privilege test user, SynapseCyber altered the accountId path parameter to a value not associated with the test account and successfully retrieved a second (test) customer's statement. Access was granted with no ownership check. All records handled during testing were Client-provisioned test data; production customer data was not accessed.

#### Business Impact

An authenticated attacker (or any compromised customer account) can iterate through identifiers to extract personal and financial information at scale, constituting a large-volume privacy breach under PIPEDA.

#### Likelihood / Exploitability

High. Object enumeration requires only a valid low-privilege session and trivial request manipulation.

#### Steps to Reproduce (sanitised)

1. Authenticate to the portal as a standard customer (test account).
2. Capture a request to the account-statements API.
3. Substitute the accountId path value with an identifier outside the test account's ownership.
4. Observe that another account's statement is returned without authorisation error.

## Remediation

- Enforce server-side, object-level authorisation on every request: confirm the authenticated principal is entitled to the specific object referenced.
- Adopt unpredictable, non-sequential identifiers (UUIDv4) as defence-in-depth; note that opaque identifiers are not a substitute for authorisation checks.
- Add automated access-control test coverage (horizontal and vertical privilege) to the regression suite.
- Centralise authorisation decisions in a reusable policy layer rather than per-endpoint logic.

## References

- CWE-639 / CWE-285: Improper Authorization
- OWASP Top 10 A01:2021
- OWASP API Security Top 10, API1:2023 (BOLA)
- OWASP WSTG-ATHZ-04

## 4.4 SC-004: End-of-Life Edge Appliance with Known Exploitable Vulnerabilities

**HIGH** · S.I.R.P. 8.6 · CVSS v4.0 8.6 · SSVC: Act

|             |                                                  |                 |                                            |
|-------------|--------------------------------------------------|-----------------|--------------------------------------------|
| SEVERITY    | High (S.I.R.P. 8.6)                              | CVSS V4.0       | 8.6                                        |
| ASSET TIER  | Tier 1 (Internet-facing)                         | REMEDIATION SLA | Immediate (≤ 72 h)                         |
| EPSS        | 0.91 (98th pct)                                  | SSVC DECISION   | Act                                        |
| CWE         | CWE-1104                                         | CATEGORY        | A06:2021, Vulnerable & Outdated Components |
| CVSS VECTOR | CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H |                 |                                            |

### Affected Assets

Internet-facing edge appliance, [REDACTED] (model/version redacted)

### Description

An internet-facing edge appliance is running a vendor-unsupported (end-of-life) firmware release affected by multiple publicly disclosed, remotely exploitable vulnerabilities. At least one associated CVE is listed in the CISA Known Exploited Vulnerabilities (KEV) catalogue and has a high EPSS score, indicating confirmed exploitation in the wild [CVE redacted].

### Evidence

Service and version fingerprinting identified the end-of-life firmware build. The identified version was cross-referenced against vendor security advisories, the CISA KEV catalogue, and EPSS data. Exploitation was not attempted against the appliance to avoid service disruption, per the agreed rules of engagement.

### Business Impact

Pre-authentication remote code execution is plausible given the published vulnerabilities; compromise of an edge device would provide a privileged network position and potential pivot into internal systems.

### Likelihood / Exploitability

High. KEV listing and high EPSS indicate active, opportunistic exploitation of comparable deployments.

### Steps to Reproduce (sanitised)

1. Passive and active service fingerprinting of the edge appliance.
2. Correlation of the version banner with vendor advisories and the CISA KEV catalogue.
3. Exploitation withheld under the rules of engagement; details omitted from this redacted sample.

### Remediation

- Treat as an emergency change: upgrade to a vendor-supported release, or decommission and replace the appliance.

- Where immediate upgrade is infeasible, apply virtual patching at an upstream WAF/IPS and restrict the appliance's exposed surface to required sources only.
- Establish a lifecycle-management process to identify and retire end-of-life assets before vendor support lapses.
- Subscribe to vendor advisories and integrate KEV/EPSS feeds into the vulnerability-management workflow.

## References

- CWE-1104: Use of Unmaintained Third Party Components
- OWASP Top 10 A06:2021
- CISA Known Exploited Vulnerabilities Catalogue
- Vendor Security Advisory (redacted)

## 4.5 SC-005: Source Code & Configuration Exposure via Accessible .git Directory

**MEDIUM** · S.I.R.P. 6.4 · CVSS v4.0 6.5 · SSVC: Attend

|             |                                                  |                 |                                     |
|-------------|--------------------------------------------------|-----------------|-------------------------------------|
| SEVERITY    | Medium (S.I.R.P. 6.4)                            | CVSS V4.0       | 6.5                                 |
| ASSET TIER  | Tier 1 (Internet-facing)                         | REMEDIATION SLA | 30 days                             |
| EPSS        | 0.30 (82nd pct)                                  | SSVC DECISION   | Attend                              |
| CWE         | CWE-538                                          | CATEGORY        | A05:2021, Security Misconfiguration |
| CVSS VECTOR | CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:N/VA:N |                 |                                     |

### Affected Assets

<https://www.██████████.com/.git/>

### Description

The public web root exposes a version-control (.git) directory, allowing retrieval of repository metadata and reconstruction of application source code. Source disclosure reveals application logic, internal endpoints, and the structure of server-side processing.

### Evidence

SynapseCyber confirmed that .git/HEAD and associated repository objects were retrievable, and that partial source reconstruction was achievable from the exposed metadata. No plaintext production secrets were identified within the recovered history during the assessment window. Had credentials or API keys been present, this finding would escalate to High or Critical.

### Business Impact

Disclosed source code accelerates discovery of further vulnerabilities (logic flaws, hidden endpoints, hard-coded values) and materially lowers attacker effort. Exposure of embedded secrets, if present, would enable direct compromise.

### Likelihood / Exploitability

Medium. Discovery is trivial via automated dotfile scanning; impact depends on what the repository contains.

### Steps to Reproduce (sanitised)

1. Request /.git/HEAD against the web root and confirm a valid response.
2. Enumerate referenced repository objects to reconstruct source where accessible.
3. Specific paths and recovered content are omitted from this redacted sample.

### Remediation

- Remove all version-control metadata from web-served directories; deploy from build artefacts, not working repositories.
- Configure the web server / CDN to deny access to dotfiles and VCS directories (.git, .svn, .hg).

- Integrate automated secret scanning into CI/CD and rotate any credential ever committed to history.
- Add a recurring external check for exposed sensitive paths to the monitoring baseline.

**References**

- CWE-538: Insertion of Sensitive Information into Externally-Accessible File
- OWASP Top 10 A05:2021
- OWASP WSTG-CONF-05

## 4.6 SC-006: Weak Transport Layer Security (TLS) Configuration

**MEDIUM** · S.I.R.P. 5.8 · CVSS v4.0 5.9 · SSVC: Attend

|             |                                                  |                 |                                  |
|-------------|--------------------------------------------------|-----------------|----------------------------------|
| SEVERITY    | Medium (S.I.R.P. 5.8)                            | CVSS V4.0       | 5.9                              |
| ASSET TIER  | Tier 1 (Internet-facing)                         | REMEDIATION SLA | 30 days                          |
| EPSS        | 0.06 (52nd pct)                                  | SSVC DECISION   | Attend                           |
| CWE         | CWE-326                                          | CATEGORY        | A02:2021, Cryptographic Failures |
| CVSS VECTOR | CVSS:4.0/AV:N/AC:H/AT:P/PR:N/UI:N/VC:H/VI:L/VA:N |                 |                                  |

### Affected Assets

Multiple HTTPS endpoints (redacted)

### Description

Several HTTPS endpoints negotiate deprecated protocol versions (TLS 1.0 / 1.1) and offer weak cipher suites. HTTP Strict Transport Security (HSTS) is not enforced, and the configuration permits protocol-downgrade conditions on hostile networks.

### Evidence

TLS configuration assessment identified support for deprecated protocols and non-AEAD cipher suites, together with the absence of an HSTS policy. Detailed scan output is redacted from this sample.

### Business Impact

On an attacker-controlled or shared network, downgrade and man-in-the-middle conditions could expose session data in transit. The exposure does not affect connections that negotiate modern protocols, which constrains overall severity.

### Likelihood / Exploitability

Medium. Exploitation requires a privileged network position (e.g., hostile Wi-Fi), reducing practicality against most users.

### Steps to Reproduce (sanitised)

1. Enumerate supported protocols and cipher suites for each HTTPS endpoint.
2. Confirm negotiation of deprecated protocol versions and absence of HSTS.

### Remediation

- Disable TLS 1.0 and 1.1; require TLS 1.2 as a minimum and prefer TLS 1.3.
- Restrict cipher suites to strong AEAD configurations and enable forward secrecy.
- Enable HSTS with an appropriate max-age (and consider preload) once HTTPS coverage is verified.
- Enable OCSP stapling and align cryptographic settings with CCCS ITSP.40.062.

## References

- CWE-326: Inadequate Encryption Strength
- OWASP Top 10 A02:2021
- CCCS ITSP.40.062: Guidance on Securely Configuring Network Protocols
- Mozilla Server-Side TLS Guidance

## 4.7 SC-007: Missing HTTP Security Headers

**MEDIUM** · S.I.R.P. 5.2 · CVSS v4.0 5.3 · SSVC: Attend

|             |                                                  |                 |                                     |
|-------------|--------------------------------------------------|-----------------|-------------------------------------|
| SEVERITY    | Medium (S.I.R.P. 5.2)                            | CVSS V4.0       | 5.3                                 |
| ASSET TIER  | Tier 1 (Internet-facing)                         | REMEDIATION SLA | 30 days                             |
| EPSS        | 0.04 (40th pct)                                  | SSVC DECISION   | Attend                              |
| CWE         | CWE-693                                          | CATEGORY        | A05:2021, Security Misconfiguration |
| CVSS VECTOR | CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:P/VC:L/VI:L/VA:N |                 |                                     |

### Affected Assets

Web application responses (redacted)

### Description

Application responses omit several recommended security headers, including Content-Security-Policy, X-Content-Type-Options, Referrer-Policy, and Permissions-Policy. The absence of these defence-in-depth controls increases exposure to client-side attacks such as cross-site scripting, MIME-type confusion, and data leakage via referrer.

### Evidence

Response header inspection across representative application routes confirmed the absent and misconfigured headers. Header captures are redacted from this sample.

### Business Impact

These headers do not introduce a vulnerability in isolation but materially weaken the application's resilience against client-side exploitation and reduce the effectiveness of browser-side protections.

### Likelihood / Exploitability

Medium. The gaps amplify the impact of other client-side issues rather than constituting direct exploitation.

### Steps to Reproduce (sanitised)

1. Inspect HTTP response headers for representative application routes.
2. Confirm the absence or misconfiguration of recommended security headers.

### Remediation

- Implement a restrictive Content-Security-Policy and progressively tighten it using report-only mode.
- Set X-Content-Type-Options: nosniff, a least-privilege Referrer-Policy, and a Permissions-Policy disabling unused browser features.
- Centralise header management at the application gateway / reverse proxy for consistent enforcement.

## References

- CWE-693: Protection Mechanism Failure
- OWASP Secure Headers Project
- OWASP WSTG-CONF-12

## 4.8 SC-008: Verbose Error Messages Disclosing Stack Traces and Internal Details

**MEDIUM** · S.I.R.P. 5.0 · CVSS v4.0 5.3 · SSVc: Attend

|             |                                                  |                  |                                     |
|-------------|--------------------------------------------------|------------------|-------------------------------------|
| SEVERITY    | Medium (S.I.R.P. 5.0)                            | CVSS V4.0        | 5.3                                 |
| ASSET TIER  | Tier 1 (Internet-facing)                         | REMEDIACTION SLA | 30 days                             |
| EPSS        | 0.05 (46th pct)                                  | SSVC DECISION    | Attend                              |
| CWE         | CWE-209                                          | CATEGORY         | A05:2021, Security Misconfiguration |
| CVSS VECTOR | CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N |                  |                                     |

### Affected Assets

Customer portal and API (redacted)

### Description

Unhandled application exceptions return detailed diagnostic output to the client, including stack traces, framework and library versions, internal file paths, and fragments of backend queries. This information aids reconnaissance and can directly reveal exploitable conditions.

### Evidence

Malformed and unexpected inputs to several endpoints produced verbose error responses exposing internal implementation details. The disclosed query fragments corroborated the injection condition documented in SC-001.

### Business Impact

Detailed error output lowers attacker effort by revealing technology stack, internal structure, and potential injection points, and may leak limited sensitive data.

### Likelihood / Exploitability

Medium. Triggering verbose errors requires only malformed input; the disclosed detail accelerates other attacks.

### Steps to Reproduce (sanitised)

1. Submit malformed or unexpected input to application endpoints.
2. Observe diagnostic detail (stack traces, paths, versions) returned in responses.

### Remediation

- Return generic, user-safe error messages; log detailed diagnostics server-side only.
- Disable debug / development error modes in all non-development environments.
- Implement centralised exception handling and a global error page.
- Route detailed errors to monitored logging with correlation identifiers.

**References**

- CWE-209: Generation of Error Message Containing Sensitive Information
- OWASP Top 10 A05:2021
- OWASP WSTG-ERRH-01 / ERRH-02

## 4.9 SC-009: Session Cookies Missing Secure and HttpOnly Attributes

**LOW** · S.I.R.P. 3.4 · CVSS v4.0 3.5 · SSVC: Track

|             |                                                  |                 |                                     |
|-------------|--------------------------------------------------|-----------------|-------------------------------------|
| SEVERITY    | Low (S.I.R.P. 3.4)                               | CVSS V4.0       | 3.5                                 |
| ASSET TIER  | Tier 1 (Internet-facing)                         | REMEDIATION SLA | 90 days                             |
| EPSS        | 0.03 (33rd pct)                                  | SSVC DECISION   | Track                               |
| CWE         | CWE-614                                          | CATEGORY        | A05:2021, Security Misconfiguration |
| CVSS VECTOR | CVSS:4.0/AV:N/AC:L/AT:N/PR:L/UI:N/VC:L/VI:N/VA:N |                 |                                     |

### Affected Assets

Session management (redacted)

### Description

Session cookies are issued without the Secure and HttpOnly attributes and without a strict SameSite policy. As a result, session identifiers may be transmitted over cleartext channels and are accessible to client-side script.

### Evidence

Inspection of Set-Cookie headers confirmed the absence of Secure, HttpOnly, and an appropriate SameSite attribute on session cookies.

### Business Impact

Increases the risk of session-token theft via network interception or client-side script (in the presence of an XSS condition), and weakens cross-site request protections.

### Likelihood / Exploitability

Low. Exploitation typically depends on a co-existing condition such as XSS or an insecure transport path.

### Steps to Reproduce (sanitised)

1. Inspect Set-Cookie response headers for session cookies.
2. Confirm the missing Secure / HttpOnly / SameSite attributes.

### Remediation

- Set Secure, HttpOnly, and SameSite=Lax (or Strict where compatible) on all session and authentication cookies.
- Scope cookies to the minimum required path and domain and use the \_\_Host- prefix where applicable.

### References

- CWE-614 / CWE-1004: Sensitive Cookie Without Secure / HttpOnly
- OWASP WSTG-SESS-02

- OWASP Session Management Cheat Sheet

## 4.10 SC-010: Web Server, Framework, and Technology Version Disclosure

**LOW** · S.I.R.P. 2.8 · CVSS v4.0 3.1 · SSVC: Track

|             |                                                  |                 |                                     |
|-------------|--------------------------------------------------|-----------------|-------------------------------------|
| SEVERITY    | Low (S.I.R.P. 2.8)                               | CVSS V4.0       | 3.1                                 |
| ASSET TIER  | Tier 1 (Internet-facing)                         | REMEDIATION SLA | 90 days                             |
| EPSS        | 0.02 (28th pct)                                  | SSVC DECISION   | Track                               |
| CWE         | CWE-200                                          | CATEGORY        | A05:2021, Security Misconfiguration |
| CVSS VECTOR | CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N |                 |                                     |

### Affected Assets

Multiple HTTP services (redacted)

### Description

HTTP responses disclose precise web-server, framework, and component versions through Server and X-Powered-By headers and default banners. This enables an attacker to map exposed software to known vulnerabilities quickly.

### Evidence

Banner and header inspection across services returned specific product and version strings.

### Business Impact

Facilitates targeted vulnerability mapping and reduces attacker reconnaissance effort. Low direct impact.

### Likelihood / Exploitability

Low. Informational disclosure; supports rather than constitutes an attack.

### Steps to Reproduce (sanitised)

1. Inspect Server, X-Powered-By, and similar response headers.
2. Note disclosed product and version detail.

### Remediation

- Suppress or generalise version-bearing headers and service banners.
- Standardise hardened response-header configuration across all services.

### References

- CWE-200: Exposure of Sensitive Information to an Unauthorized Actor
- OWASP WSTG-INFO-02 / INFO-08

## 4.11 SC-011: Clickjacking via Missing Anti-Framing Controls

**LOW** · S.I.R.P. 3.0 · CVSS v4.0 3.4 · SSVC: Track

|             |                                                  |                 |                                     |
|-------------|--------------------------------------------------|-----------------|-------------------------------------|
| SEVERITY    | Low (S.I.R.P. 3.0)                               | CVSS V4.0       | 3.4                                 |
| ASSET TIER  | Tier 1 (Internet-facing)                         | REMEDIATION SLA | 90 days                             |
| EPSS        | 0.02 (30th pct)                                  | SSVC DECISION   | Track                               |
| CWE         | CWE-1021                                         | CATEGORY        | A05:2021, Security Misconfiguration |
| CVSS VECTOR | CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:A/VC:N/VI:L/VA:N |                 |                                     |

### Affected Assets

Web application pages (redacted)

### Description

Application pages do not set anti-framing controls (X-Frame-Options or a Content-Security-Policy frame-ancestors directive) and can therefore be embedded within attacker-controlled frames, enabling clickjacking / UI-redress attacks against authenticated users.

### Evidence

Application responses lacked X-Frame-Options and a frame-ancestors directive; a proof-of-concept frame embedding was demonstrated against representative pages.

### Business Impact

An attacker could trick an authenticated user into performing unintended actions by overlaying deceptive UI over a framed application page.

### Likelihood / Exploitability

Low. Requires social engineering of an authenticated user to a malicious page.

### Steps to Reproduce (sanitised)

1. Confirm responses omit X-Frame-Options and CSP frame-ancestors.
2. Demonstrate framing of a representative page in a controlled proof of concept.

### Remediation

- Set Content-Security-Policy: frame-ancestors 'none' (or an explicit allow-list).
- Set X-Frame-Options: DENY as a legacy-browser fallback.

### References

- CWE-1021: Improper Restriction of Rendered UI Layers
- OWASP WSTG-CLNT-09
- OWASP Clickjacking Defense Cheat Sheet

## 4.12 SC-012: Email Authentication (SPF / DKIM / DMARC) Hardening Opportunities

**INFORMATIONAL** · S.I.R.P. N/A · CVSS v4.0 N/A · SSVC: Track

|                    |                              |                        |                                          |
|--------------------|------------------------------|------------------------|------------------------------------------|
| <b>SEVERITY</b>    | Informational (S.I.R.P. N/A) | <b>CVSS V4.0</b>       | N/A                                      |
| <b>ASSET TIER</b>  | Tier 1 (Public DNS)          | <b>REMEDIATION SLA</b> | Advisory                                 |
| <b>EPSS</b>        | N/A                          | <b>SSVC DECISION</b>   | Track                                    |
| <b>CWE</b>         | CWE-358                      | <b>CATEGORY</b>        | Email Authentication / Domain Protection |
| <b>CVSS VECTOR</b> | Not applicable (advisory)    |                        |                                          |

### Affected Assets

Public DNS records for ██████████.com

### Description

The domain publishes SPF and DKIM records, but the configuration leaves room for hardening. The SPF policy uses a soft-fail qualifier, and the DMARC policy is set to monitoring only (p=none), which does not instruct receivers to reject or quarantine spoofed mail. This weakens resistance to brand impersonation and phishing that spoofs the organisation's domain.

### Evidence

Public DNS records were reviewed for SPF, DKIM selectors, and DMARC policy. SPF terminated in a soft-fail qualifier and DMARC was published with p=none.

### Business Impact

Weak enforcement increases the likelihood that spoofed mail purporting to originate from the domain reaches recipients, supporting phishing and business-email-compromise campaigns that target customers and staff.

### Likelihood / Exploitability

Informational. No direct system compromise; reduces phishing resistance.

### Steps to Reproduce (sanitised)

1. Query public SPF, DKIM, and DMARC records for the domain.
2. Confirm the SPF soft-fail qualifier and DMARC p=none policy.

### Remediation

- Tighten SPF to a hard-fail qualifier once all legitimate senders are inventoried.
- Progress the DMARC policy from p=none to p=quarantine and ultimately p=reject, monitoring aggregate reports at each stage.
- Ensure DKIM signing uses 2048-bit keys with a defined rotation schedule.
- Consider BIMl to reinforce brand presentation once DMARC enforcement is in place.

## References

- RFC 7208 (SPF)
- RFC 6376 (DKIM)
- RFC 7489 (DMARC)
- CCCS: Protect Against Email Spoofing

## 5. Strategic Recommendations & Remediation Roadmap

### 5.1 Root-Cause Themes & Programme Recommendations

Beyond fixing individual findings, SynapseCyber recommends the following programme-level investments to address the underlying causes and reduce the likelihood of recurrence:

- Secure software development lifecycle (SSDLC). Integrate SAST, DAST, and software-composition analysis as gating controls in the CI/CD pipeline, supported by secure-coding training and threat modelling for new features.
- Identity and access hardening. Enforce phishing-resistant MFA everywhere, adopt conditional access, and centralise object-level authorisation in a reusable policy layer with automated access-control test coverage.
- Vulnerability & attack-surface management. Maintain a continuous inventory of internet-facing assets, integrate KEV/EPSS feeds, apply risk-based remediation SLAs (S.I.R.P.), and retire end-of-life assets on a defined lifecycle.
- Secure-configuration baselines. Define and enforce hardened baselines for public services (TLS, security headers, banner suppression, cookie flags, anti-framing, email authentication), centrally managed at the gateway / CDN.
- Continuous validation. Complement annual penetration testing with periodic targeted re-testing and continuous external monitoring so that regressions and new exposures are caught between full assessments.

### 5.2 Prioritised Remediation Roadmap

The roadmap sequences remediation by S.I.R.P. priority and the recommended SLA for each affected asset tier.

| Horizon                       | Findings           | Recommended Actions                                                                                                                |
|-------------------------------|--------------------|------------------------------------------------------------------------------------------------------------------------------------|
| Immediate ( $\leq 72$ hours)  | SC-001, SC-004     | Emergency remediation: parameterise the vulnerable query / deploy WAF blocking; upgrade or isolate the end-of-life edge appliance. |
| Short term ( $\leq 7$ days)   | SC-002, SC-003     | Enforce MFA on all external access; implement server-side object-level authorisation on the statements API.                        |
| Medium term ( $\leq 30$ days) | SC-005 to SC-008   | Remove exposed .git; harden TLS and HSTS; implement security headers; suppress verbose error output.                               |
| Hardening ( $\leq 90$ days)   | SC-009 to SC-011   | Set secure cookie flags; suppress version banners; implement anti-framing controls.                                                |
| Ongoing / Strategic           | SC-012 + programme | Progress DMARC to enforcement; stand up SSDLC, vulnerability management, secure baselines, and continuous validation.              |

### 5.3 Re-Testing

SynapseCyber recommends a verification re-test of all Critical and High findings once remediation is complete, to confirm fixes are effective and have not introduced regressions. SynapseCyber's standard re-test policy is summarised in Appendix F.

## 6. Conclusion

---

The assessment identified a Critical SQL injection condition, three High-severity findings, and a series of medium and low-severity issues that together place the in-scope environment at an ELEVATED residual risk. The most serious findings provide realistic, low-effort paths for an external attacker to access customer personal and financial information, outcomes that would carry regulatory consequences under PIPEDA and OSFI Guideline B-13.

Encouragingly, the highest-impact findings are well understood and have clear, established remediations. Emergency attention to the Critical and High findings, followed by the prioritised roadmap in Section 5 and the recommended programme-level investments, will reduce the residual risk to a Moderate level and materially strengthen the Client's resilience to external attack. SynapseCyber is available to support remediation planning and to conduct verification re-testing.

## Appendices

### Appendix A: S.I.R.P. v2.1 Risk Rating Methodology

S.I.R.P. v2.1 is SynapseCyber's proprietary vulnerability risk-rating and prioritisation model. It is designed to produce ratings that are transparent, auditable, and aligned to business and regulatory context, bridging the gap between a purely technical score and the prioritisation decisions that leadership must make. S.I.R.P. reconciles four established standards within a single, consistent framework.

#### The Four Dimensions

| Dimension                  | What it Measures                                                | Anchored On                                                        |
|----------------------------|-----------------------------------------------------------------|--------------------------------------------------------------------|
| <b>Severity (S)</b>        | Intrinsic technical severity of the vulnerability               | CVSS v4.0 Base metrics                                             |
| <b>Impact (I)</b>          | Business and data impact in context of the affected asset       | OWASP Risk Rating Methodology + asset-tier and data classification |
| <b>Reproducibility (R)</b> | Practical exploitability and real-world exploitation likelihood | EPSS + CISA KEV + tester-observed exploit complexity               |
| <b>Priority (P)</b>        | Resulting remediation action and urgency                        | CISA SSVC decision points (Track / Track* / Attend / Act)          |

The four dimensions are combined into a normalised 0 to 10 composite score and a categorical rating (Critical / High / Medium / Low / Informational), accompanied by an SSVC-aligned action that drives the remediation SLA.

#### Asset Tiers

Impact is contextualised by the criticality of the affected asset. A finding's rating reflects not only the flaw but what it threatens.

| Tier                              | Definition                                                                                                            |
|-----------------------------------|-----------------------------------------------------------------------------------------------------------------------|
| <b>Tier 1 (Crown Jewel)</b>       | Internet-facing systems and systems processing regulated or sensitive data (customer PII, financial, authentication). |
| <b>Tier 2 (Business-Critical)</b> | Internal systems whose compromise would materially disrupt operations.                                                |
| <b>Tier 3 (Supporting)</b>        | Lower-sensitivity supporting systems with limited blast radius.                                                       |

#### Split-SLA Matrix

Remediation timelines are a function of both severity and asset tier: a Medium finding on a Tier-1 crown-jewel asset may warrant a tighter SLA than a High finding on a Tier-3 system.

| Severity        | Tier 1   | Tier 2  | Tier 3  |
|-----------------|----------|---------|---------|
| <b>Critical</b> | 72 hours | 7 days  | 14 days |
| <b>High</b>     | 7 days   | 30 days | 45 days |

|               |          |          |             |
|---------------|----------|----------|-------------|
| Medium        | 30 days  | 60 days  | 90 days     |
| Low           | 90 days  | 120 days | Best effort |
| Informational | Advisory | Advisory | Advisory    |

### Golden Quarter Protocol

During defined peak-risk business windows (for example fiscal year-end, tax season, or peak transaction periods), many organisations operate a change freeze that constrains routine remediation. The Golden Quarter protocol governs this tension: net-new Critical and High findings discovered during the window trigger an expedited compensating-control and risk-acceptance workflow with executive sign-off, and emergency-fix SLAs for Tier-1 assets are tightened (typically halved) rather than relaxed. This ensures the freeze does not become a window of unmanaged exposure.

*S.I.R.P. v2.1 is proprietary to SynapseCyber and is provided here so that every rating in this report is fully transparent and defensible.*

## Appendix B: CVSS v4.0 Severity Scale

CVSS v4.0 base scores map to qualitative severity ratings as follows. S.I.R.P. uses the CVSS base score as the anchor for its Severity dimension and refines the final rating with the Impact, Reproducibility, and Priority dimensions.

| Rating               | CVSS Base Score | Interpretation                     |
|----------------------|-----------------|------------------------------------|
| Critical             | 9.0 to 10.0     | Severe; exploit imminent / trivial |
| High                 | 7.0 to 8.9      | Significant impact; prioritise     |
| Medium               | 4.0 to 6.9      | Moderate; remediate in cycle       |
| Low                  | 0.1 to 3.9      | Limited impact; hardening          |
| None / Informational | 0.0             | Advisory; no direct risk           |

## Appendix C: Tools & Techniques

The engagement combined automated tooling with expert manual testing. Manual analysis was the primary method; automated tools were used to extend coverage and triage. All activity remained within the agreed rules of engagement, and no destructive or denial-of-service techniques were employed. A representative tooling summary appears in Section 2.9.

## Appendix D: MITRE ATT&CK Technique Mapping

Observed and validated techniques are mapped to the MITRE ATT&CK framework to support detection-engineering and threat-informed defence.

| Tactic            | Technique (ID)                                                         | Related Findings       |
|-------------------|------------------------------------------------------------------------|------------------------|
| Reconnaissance    | Active Scanning (T1595); Gather Victim Host Information (T1592)        | SC-010, SC-012         |
| Initial Access    | Exploit Public-Facing Application (T1190); Valid Accounts (T1078)      | SC-001, SC-004, SC-002 |
| Credential Access | Brute Force (T1110): password spraying / stuffing exposure             | SC-002                 |
| Collection        | Data from Information Repositories (T1213): unauthorised record access | SC-003                 |
| Discovery         | System Information Discovery (T1082) via verbose errors / banners      | SC-005, SC-008, SC-010 |

## Appendix E: Scope Limitations & Assumptions

- The assessment was time-boxed; absence of a finding does not prove absence of a vulnerability.
- Testing was confined to the in-scope assets and window; out-of-scope items were not evaluated.

- No destructive, denial-of-service, social-engineering, or physical techniques were used.
- Exploitation was limited to the minimum required to validate findings; no production data was exfiltrated.
- Results reflect the environment as configured during the testing window only.

## Appendix F: Re-Testing & Validation Policy

SynapseCyber offers a verification re-test of remediated findings. Re-testing confirms that fixes are effective and have not introduced regressions, and produces an updated status for each finding (Resolved / Partially Resolved / Open / Risk Accepted). Critical and High findings are recommended for re-test on completion of remediation; medium and low findings may be validated in a consolidated re-test. Re-test scope is limited to the original findings and their immediate context.

## Appendix G: Glossary

| Term               | Definition                                                                                                                          |
|--------------------|-------------------------------------------------------------------------------------------------------------------------------------|
| <b>BOLA / IDOR</b> | Broken Object-Level Authorization / Insecure Direct Object Reference: accessing another user's objects by manipulating identifiers. |
| <b>CCCS</b>        | Canadian Centre for Cyber Security: Canada's national cyber-security authority.                                                     |
| <b>CSP</b>         | Content-Security-Policy: an HTTP header that restricts resources a page may load, mitigating XSS.                                   |
| <b>CVSS</b>        | Common Vulnerability Scoring System: an open standard for rating technical vulnerability severity (v4.0 used here).                 |
| <b>CWE</b>         | Common Weakness Enumeration: a community catalogue of software and hardware weakness types.                                         |
| <b>EPSS</b>        | Exploit Prediction Scoring System: a data-driven estimate of the probability a vulnerability will be exploited in the wild.         |
| <b>FRFI</b>        | Federally Regulated Financial Institution: supervised in Canada by OSFI.                                                            |
| <b>HSTS</b>        | HTTP Strict Transport Security: instructs browsers to use HTTPS only for a domain.                                                  |
| <b>KEV</b>         | CISA Known Exploited Vulnerabilities catalogue: vulnerabilities with confirmed in-the-wild exploitation.                            |
| <b>MFA</b>         | Multi-Factor Authentication: requiring more than one independent authentication factor.                                             |
| <b>OSFI</b>        | Office of the Superintendent of Financial Institutions: Canada's federal financial regulator.                                       |
| <b>OWASP</b>       | Open Worldwide Application Security Project: community producing application-security guidance and standards.                       |
| <b>PIPEDA</b>      | Personal Information Protection and Electronic Documents Act: Canada's federal private-sector privacy law.                          |
| <b>PTaaS</b>       | Penetration Testing as a Service: continuous / on-demand testing delivered through a managed platform.                              |
| <b>S.I.R.P.</b>    | SynapseCyber's Severity / Impact / Reproducibility / Priority risk-rating model (Appendix A).                                       |
| <b>SSVC</b>        | Stakeholder-Specific Vulnerability Categorization: CISA's decision model for prioritising remediation.                              |
| <b>WAF</b>         | Web Application Firewall: filters and blocks malicious HTTP traffic to web applications.                                            |

## Appendix H: Standards & References

- OWASP Top 10 (2021) and OWASP API Security Top 10 (2023).

- OWASP Web Security Testing Guide, v4.2.
- NIST SP 800-115: Technical Guide to Information Security Testing and Assessment.
- FIRST: Common Vulnerability Scoring System (CVSS) v4.0 Specification.
- FIRST: Exploit Prediction Scoring System (EPSS).
- CISA: Stakeholder-Specific Vulnerability Categorization (SSVC) and Known Exploited Vulnerabilities (KEV) Catalogue.
- MITRE ATT&CK Enterprise Matrix.
- Canadian Centre for Cyber Security: ITSG-33 and ITSAP guidance series.
- OSFI Guideline B-13: Technology and Cyber Risk Management.
- Office of the Privacy Commissioner of Canada: PIPEDA guidance.

---

*End of Report*

SynapseCyber · Confidential, Redacted Sample · SC-2026-PT-0142